

Rules of Engagement

Scope, exclusions, and authorization for an application penetration test

Christian Bai | Redacted work sample

The authorization document that defines what a tester may touch, when, and what is explicitly out of bounds. Every client identifier, contact, hostname, IP address and date has been removed. The structure, the methodology basis and the exclusions are intact.

Rules of Engagement

Background

This document serves to authorize the penetration testing services to be performed by [REDACTED] as defined in the engagement letter between [REDACTED] and [REDACTED] ("the Company").

[REDACTED]'s penetration testing methodology is based upon the National Institute of Standards and Technology (NIST) SP 800-115 and the Open-Source Security Testing Methodology Manual (OSSTMM).

Scope

Application Penetration Testing

The following application(s) and their respective APIs are in scope for testing. Please include multiple tenants and roles to ensure all authorization scenarios are tested.

URL User Account Role

[REDACTED] [pentest+user1@\[REDACTED\].com](#) Developer (with Full Access group assigned)

[REDACTED] [pentest+user2@\[REDACTED\].com](#) Admin (with Full Access group assigned)

[REDACTED] [pentest+user3@\[REDACTED\].com](#) Standard User

Additional Notes

Please include any additional notes that will assist with testing:

You ("the Company") authorize [REDACTED] to attack the targets listed above. By its nature, penetration testing increases the risk that applications and servers may become unresponsive or that database tables may become corrupted. We take strong precautions to minimize the impact of our testing procedures on the target systems but to mitigate the risk further; the following guidelines should be performed:

- All targeted systems and relevant databases should be backed up before the start of the engagement.
- Test or QA instances of targeted applications and databases should be used as the penetration test target where possible.

The following testing activities will be excluded from the test:

- Denial of Service (DoS)
- The use of malignant database queries, such as deletes, updates, drop tables, etc.
- Any testing disallowed by AWS, Azure, GCP or other cloud platforms' penetration testing policies.

Assessment Schedule

Testing will be performed utilizing a 24-hr. testing window on weekdays and during weekends. Testing hours are at the discretion of the client as needed.

The assessment will be performed according to the following schedule:

Task Dates

Sign and Return Rules of Engagement Prior to the start of testing

Testing Window From [REDACTED] to [REDACTED]

Report Delivery Two weeks after the final day of testing

Remediation Testing Up to 90 days after receiving the report

[REDACTED] Contacts and Testing Infrastructure

Testing will be performed by [REDACTED] ([REDACTED]). His direct cell is [REDACTED].

For any escalation, please contact [REDACTED] ([REDACTED]).

Testing will be performed from the following IP addresses:

[REDACTED]

Client Contacts

Please provide contact information for the employees within your company who will be responsible for the penetration testing.

Name	Email	Contact Type
------	-------	--------------

[REDACTED]	[REDACTED]	[Primary Contact]{.mark}
------------	------------	--------------------------

[REDACTED]	[REDACTED]	Primary Technical Contact
------------	------------	---------------------------

[REDACTED]	[REDACTED]	Technical Contact- [REDACTED]
------------	------------	-------------------------------

[REDACTED]	[REDACTED]	Technical Contact- [REDACTED]
------------	------------	-------------------------------

Acknowledgment and Consent

For the purpose of performing the penetration testing services outlined in this Rules of Engagement between [REDACTED] and the Company, the signature below acknowledges:

1. Consent to perform penetration testing activities during the specified testing window.
2. Confirms that all recommended pre-testing activities listed above have been completed.
3. Understands the inherent risks to system performance and availability associated with performing penetration testing activities.
4. Releases [REDACTED] from all liability for damages that may result from penetration testing except as provided for in the Statement of Work.
5. Due to the confidential nature and information contained within this document, [REDACTED] suggests that the Company return this document in an encrypted or secure manner.

Name: _____ Date: _____